

TECHNICAL DETAIL

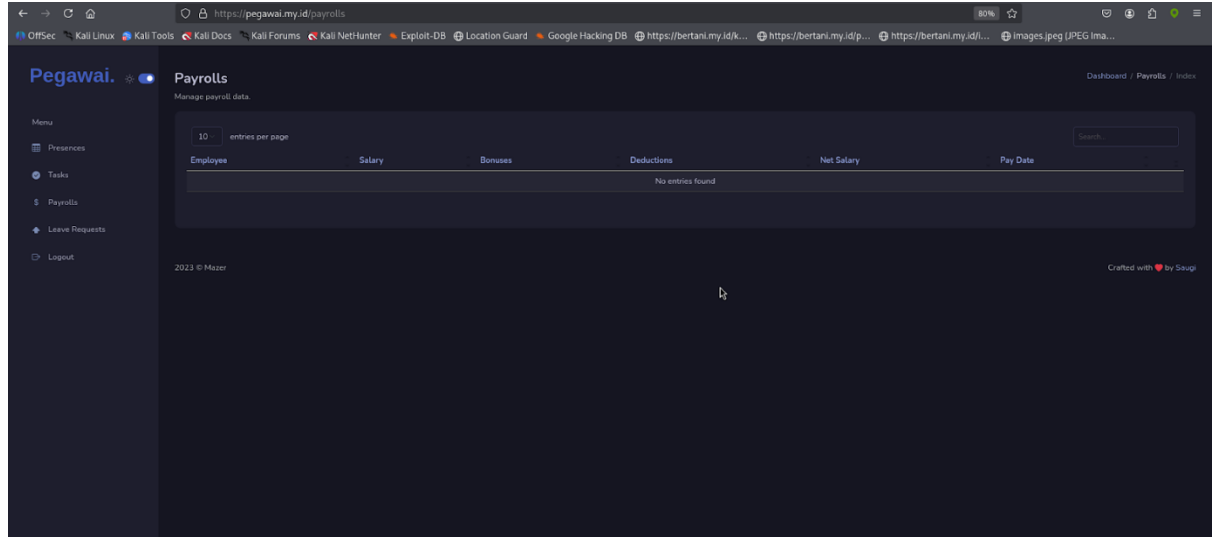
Title	Broken Access Control: Unauthorized Payroll Data Creation Leading to Financial Integrity Violation
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/payrolls/create
Severity	High
CVSS Score	8.1 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

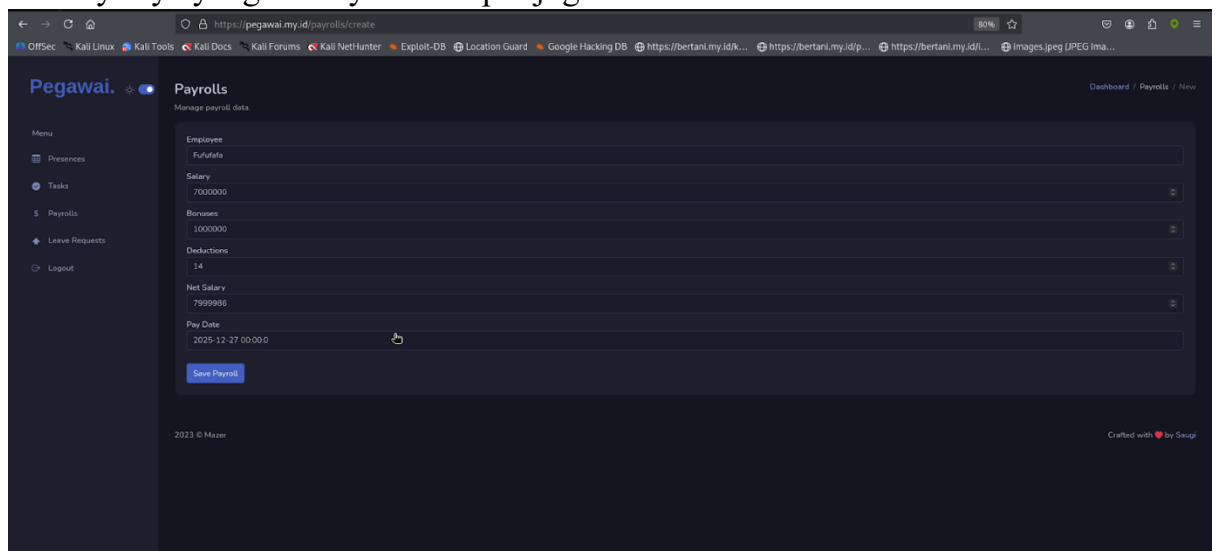
Ditemukan kerentanan Broken Access Control pada fitur penggajian (*Payrolls*) di platform pegawai.my.id. Pengguna dengan hak akses rendah (peran *Developer*) dapat melakukan Force Browsing ke endpoint administratif /payrolls/create untuk membuat data gaji baru. Hal ini mengakibatkan kegagalan otoritas di sisi server yang memungkinkan pengguna tidak berwenang untuk menyuntikkan data finansial baru bagi diri sendiri atau pengguna lain ke dalam database perusahaan.

STEPS TO REPRODUCE

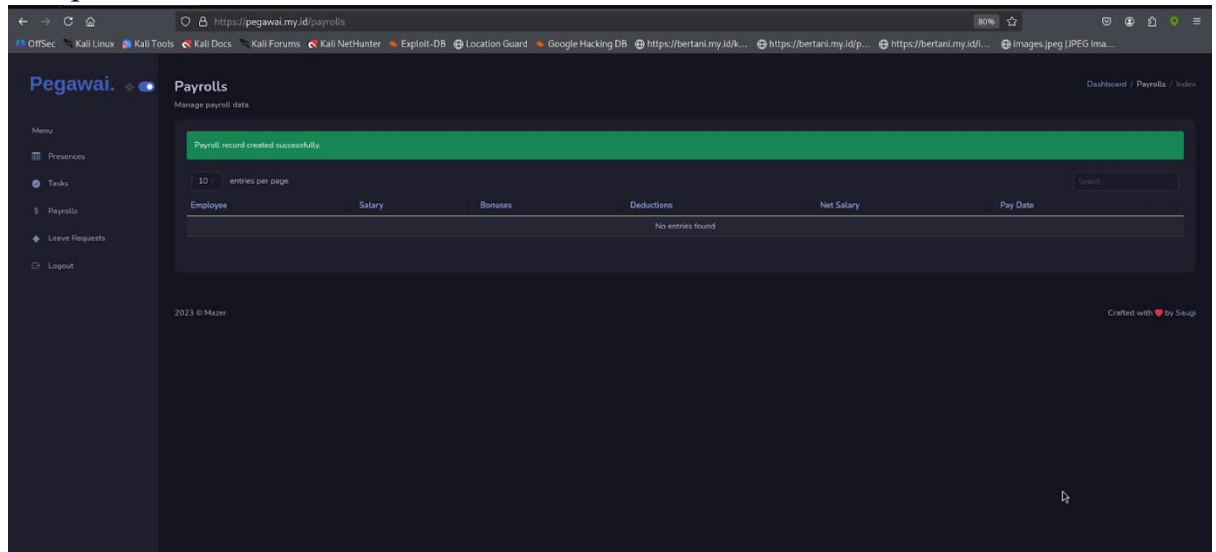
1. Login ke akun Anda yang memiliki role developer
2. Buka url <https://pegawai.my.id/payrolls> disini terlihat tidak ada fitur create



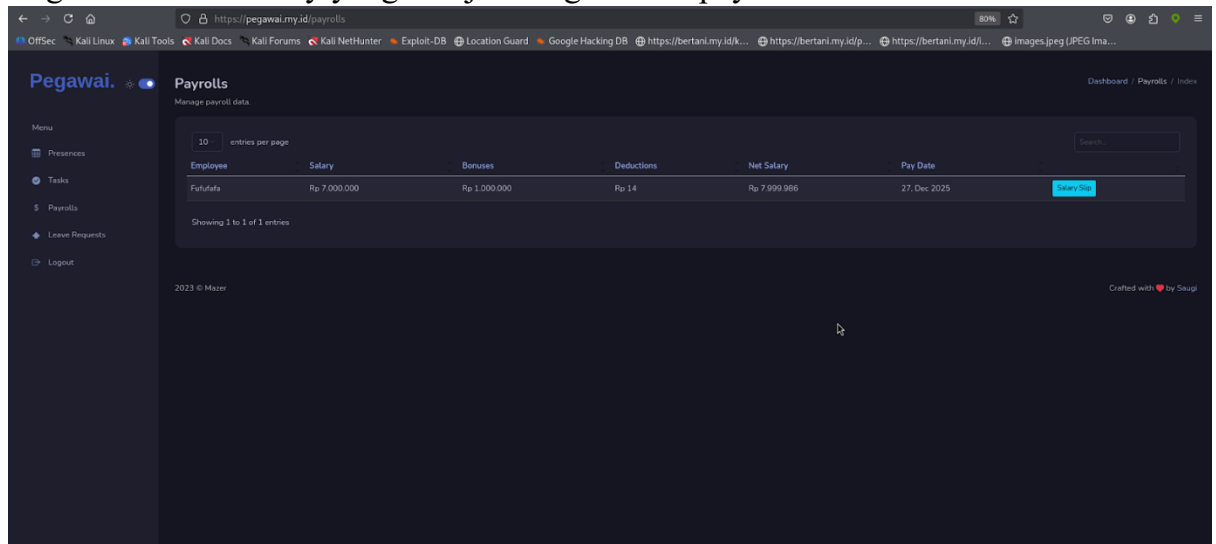
3. Lalu tambahkan /payrolls/create di urlnya menjadi <https://pegawai.my.id/payrolls/create> disini saya masukan targetnya ke akun dummy saya yang role nya developer juga



4. Tampilan saat berhasil edit



5. Login ke akun dummy yang menjadi target maka payrolls bisa masuk



EXPECTED RESULT

Endpoint `/payrolls/create` seharusnya dilindungi secara ketat oleh *middleware* otorisasi dan hanya dapat diakses oleh Administrator atau departemen Keuangan. Pengguna dengan peran lain yang mencoba mengakses URL tersebut seharusnya menerima respons 403 Forbidden atau dialihkan kembali ke halaman utama.

ACTUAL RESULT

Endpoint `/payrolls/create` seharusnya dilindungi secara ketat oleh *middleware* otorisasi dan hanya dapat diakses oleh Administrator atau departemen Keuangan. Pengguna dengan peran lain yang mencoba mengakses URL tersebut seharusnya menerima respons 403 Forbidden atau dialihkan kembali ke halaman utama.

IMPACT

- 1. Financial Integrity Violation:** Penyerang dapat membuat data gaji fiktif atau memberikan bonus ilegal kepada diri sendiri atau rekan kerja, yang berpotensi menyebabkan kerugian finansial nyata bagi organisasi.
- 2. Bypass Business Logic:** Melewati alur otorisasi internal perusahaan terkait persetujuan dan pembuatan data penggajian.
- 3. Audit Failure:** Merusak validitas data audit internal karena adanya entri data finansial dari pihak yang tidak berwenang

RECOMMENDATION

- 1. Implementasi Middleware Otorisasi:** Terapkan *middleware* pengecekan peran (seperti `isAdmin` atau `can:manage-payroll`) pada rute `/payrolls/create` dan fungsi `store()` di *Controller* terkait.
- 2. Server-Side Role Validation:** Pastikan logika di *backend* selalu memverifikasi hak akses pengguna sebelum memproses aksi penulisan (*Write*) pada database finansial.
- 3. Gunakan URL yang Tidak Terprediksi:** Gunakan UUID atau *slug* acak untuk mempersulit penemuan URL administratif sebagai bagian dari strategi pertahanan berlapis.

REFERENCES

1. **OWASP Top 10 - A01:2021 Broken Access Control:**
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-639: Authorization Bypass Through User-Controlled Key:**
<https://cwe.mitre.org/data/definitions/639.html>